Software Test Plan (STP)

Simplified GDPR Consent Manager

Project: Simplified GDPR Consent Manager
Team: Team 6
Version: 1.0
Authors: QA Lead: Suman Diddimani (PES1UG24AM409), Test Eng: Pradeep T (PES1UG24AM385)
Co-Authors: Dev Lead: Vilas (PES1UG24AM415), Frontend Lead: Pranaav Prabhakaran (PES1UG24AM387)
Date: 10-10-2026
Status: Baseline / Approved

Team Members

#	Name	SRN	Test Role & Verification Responsibilities
1	SUMAN DIDDIMANI	PES1UG24AM409	QA Lead / Test Plan Architecture, Security Verification, RTM Governance & Sign-off
2	PRADEEP T	PES1UG24AM385	Test & Automation Engineer / Automated Test Scripts, Performance/Load Testing, CI/CD Integration
3	VILAS	PES1UG24AM415	Development Lead / Backend Defect Triage, Database Transaction Verification, API Testing Support
4	PRANAAV PRABHAKARAN	PES1UG24AM387	Frontend Lead / UI Functional Testing, WCAG 2.1 AA Accessibility Testing, Cross-Browser Tests

Revision History

Version	Date	Author	Change Summary	Approval Status
0.1	06-10-2026	Suman Diddimani	Initial test strategy, test scope, and test environment definitions	Draft
0.2	08-10-2026	Pradeep T, Suman Diddimani	Added full test suite definitions (TC-AUTH, TC-CONS, TC-SEC, TC-PERF, etc.) and RTM	Reviewed
1.0	10-10-2026	Team 6	Finalized complete STP aligned with SRS v1.0 and SAD v1.0	Baseline Approved
1.1	03-11-2026	Team 6 (Pradeep T)	Test cases revised to match the implemented system (blue text); all 41 executed with actual results (green); RTM status updated to P; execution results, defects and deviations added (section 14.1)	Executed - Sprint 3

Table of Contents

• 1. Introduction (Purpose, Scope, References, Definitions and Acronyms)
• 2. Test Items (System Modules & Components Under Test)
• 3. Features to be Tested (Mapping to Functional, Security, and Non-Functional Requirements)
• 4. Features Not to be Tested (Exclusions & System Boundaries)
• 5. Test Approach / Strategy (Test Levels, Test Types, Entry & Exit Criteria, Security Validation)

• 6. Test Environment (Hardware, Software, Testing Tools, Test Data Sets)
• 7. Test Schedule & Milestones (Sprint 1, Sprint 2, UAT & Sign-off)
• 8. Test Deliverables (Artefacts Produced Across Test Lifecycle)
• 9. Roles and Responsibilities (QA Team Allocation Matrix)
• 10. Risks and Mitigation (Testing Challenges & Contingencies)
• 11. Assumptions & Dependencies
• 12. Suspension & Resumption Criteria
• 13. Test Case Management & Traceability (Detailed Test Case Specifications & RTM)
• 14. Test Metrics & Reporting
• 15. Approvals

1. Introduction

1.1 Purpose

This Software Test Plan (STP) defines the verification and validation framework for the Simplified GDPR Consent Manager v1.0. It documents the testing scope, objectives, technical strategy, execution levels, test toolchains, resource allocations, sprint testing milestones, risks, quantitative pass/fail criteria, and detailed test case specifications to ensure that the system rigorously satisfies all requirements defined in the SRS v1.0 and conforms to the architectural design specified in the SAD v1.0.

Special testing rigor is directed toward validating the immutability of the append-only consent ledger, the non-repudiation of UTC timestamps, the transactional atomicity of consent and audit logs (NFR-5), and strict server-side role-based access control (SEC-2).

1.2 Scope

The testing scope encompasses all functional, security, performance, reliability, usability, and data-integrity aspects of the Simplified GDPR Consent Manager across three tiers:

- **Authentication & Access:** Verification of User registration, credential authentication, bcrypt password hashing, account lockout mechanisms, and server-enforced RBAC for User, Administrator, and DPO_Auditor roles.
- **Consent Management Engine:** Verification of purpose display, policy version presentation, granular opt-in (grant) and opt-out (withdraw) workflows, UTC timestamping, and current consent state derivation.
- **Consent History & Lineage:** Verification of append-only storage guarantees, reverse-chronological history presentation, and immutability (prohibiting SQL UPDATE/DELETE).
- **Policy Lifecycle:** Verification of Draft, Published, and Superseded policy version lifecycles, user re-consent notifications, and immutable historical policy retention.
- **Compliance & Auditability:** Verification of structured audit trail logging, DPO search/filtering across multiple criteria, and deterministic point-in-time historical consent state reconstruction.
- **Quality Attributes & NFRs:** Measurement of API latencies (≤2s for consent, ≤3s for search), concurrent load (50 users, 500k records), 99% availability, and WCAG 2.1 AA accessibility compliance.

1.3 References

- **SRS:** Simplified GDPR Consent Manager - Software Requirements Specification (SRS) v1.0, Team 6 (October 2026).
- **SAD:** Simplified GDPR Consent Manager - Software Architecture and Design Specification (SAD) v1.0, Team 6 (October 2026).
- **ISO 29119:** ISO/IEC/IEEE 29119-3:2021: Software and Systems Engineering - Software Testing - Test Documentation.
- **IEEE 829:** IEEE Std 829-2008: IEEE Standard for Software and System Test Documentation.
- **OWASP WSTG:** OWASP Web Security Testing Guide (WSTG) v4.2.

1.4 Definitions and Acronyms

Term / Acronym	Full Definition in Software Testing Context
STP	Software Test Plan; master document defining strategy, scope, resources, schedule, and deliverables.
RTM	Requirements Traceability Matrix; bidirectional mapping connecting SRS requirements to test cases.
UAT	User Acceptance Testing; validation testing conducted to determine if the system satisfies user needs.
Append-Only Verification	Negative test methodology asserting that SQL UPDATE and DELETE operations are rejected by the store.
STRIDE Testing	Security test suite verifying countermeasures against Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation.
WCAG 2.1 AA	Accessibility benchmark testing keyboard navigation, color contrast ratios, and aria screen reader semantics.
RPO / RTO	Recovery Point Objective (target ≤24h) and Recovery Time Objective (target ≤4h) disaster recovery thresholds.

2. Test Items

The software items and subsystems subjected to testing comprise:

- **Item 1: Authentication & RBAC Module -** Registration controller, login validator, bcrypt password hasher, JWT token generator, account lockout interceptor.
- **Item 2: Purpose & Policy Presentation Module -** Purpose catalog provider, active/inactive purpose state manager, policy text renderer.
- **Item 3: Consent Management Service -** Opt-in/opt-out transaction coordinator, NTP UTC timestamp recorder, policy link binder, state evaluator.
- **Item 4: Consent History Service -** Append-only consent ledger reader, reverse-chronological query optimizer, pagination engine.
- **Item 5: Policy Versioning Service -** Draft editor, publication state machine (Draft -> Published -> Superseded), user policy update alert dispatcher.
- **Item 6: Audit & Compliance Review Service -** Structured security event logger, SHA-256 hash chaining engine, DPO audit trail inspector.
- **Item 7: Search & Historical State Service -** Multi-parameter filter engine, point-in-time state reconstruction algorithm folding append-only history up to timestamp T.
- **Item 8: Database & Persistence Layer -** PostgreSQL schema constraints, immutable table rules, daily pg_dump backup and recovery scripts.

3. Features to be Tested

The features to be tested are strictly mapped to SRS Requirement IDs:

- **Functional Requirements - Authentication:** FR-1 (Registration), FR-2 (Login & role-based home screen), FR-3 (Logout).
- **Functional Requirements - Presentation:** FR-4 (Active purposes display), FR-5 (Published policy display), FR-6 (Admin purpose management).
- **Functional Requirements - Consent Management:** FR-7 (Explicit opt-in), FR-8 (Explicit opt-out), FR-9 (UTC timestamp & policy binding), FR-10 (Rejection of invalid consent actions).
- **Functional Requirements - History:** FR-11 (Append-only storage), FR-12 (Reverse-chronological history view).
- **Functional Requirements - Policy Lifecycle:** FR-13 (Create draft policy), FR-14 (Publish policy), FR-15 (Retain superseded policies), FR-16 (User re-consent alerts).
- **Functional Requirements - Audit & Compliance:** FR-17 (Audit logging), FR-18 (DPO real-time view), FR-19 (DPO search/filter), FR-20 (Point-in-time state reconstruction).

- **Security Requirements:** SEC-1 (Password policy & bcrypt), SEC-2 (Server RBAC), SEC-3 (Account lockout & session expiry), SEC-4 (Admin role governance), SEC-5 (TLS 1.2+ encryption), SEC-6 (Ledger immutability), SEC-7 (Input validation / OWASP).
- **Non-Functional Requirements:** NFR-1 (Consent latency ≤2s), NFR-2 (Search latency ≤3s), NFR-3 (50 concurrent users / 500k records), NFR-4 (99% uptime), NFR-5 (Transactional atomicity), NFR-6 (≤3 clicks usability), NFR-7 (WCAG 2.1 AA), NFR-8 (Retention), NFR-9 (Data minimization), NFR-10 (Encryption at rest), NFR-11 (Recovery RTO/RPO), NFR-12 (Maintainability ≥70% coverage), NFR-13 (NTP UTC clock), NFR-14 (RTM traceability).

4. Features Not to be Tested

The following features and integrations are explicitly out of scope for testing:

- Downstream business consumption of personal data (marketing email delivery engines, third-party analytics pipelines).
- Automated legal interpretation or formal legal GDPR compliance certification.
- Real-world integrations with national data protection authority portals.
- Enterprise single sign-on (SSO/SAML/LDAP) and hardware biometric scanners.
- Hardware-level physical server failures or bare-metal data center maintenance.

5. Test Approach / Strategy

5.1 Testing Levels

- **1. Unit Testing:** Automated module-level tests using Jest. Validates pure business logic, password validators, date parsers, state recalculation routines, and hash calculations in isolation. Minimum 70% service-layer coverage target (NFR-12).
- **2. Integration Testing:** API endpoint tests using Supertest and an isolated PostgreSQL container. Validates request validation, JWT authentication filters, RBAC guards, and database transactional atomicity (NFR-5).
- **3. System Testing:** End-to-end user journeys executed via Cypress in headless Chrome and Firefox. Validates browser UI state, toggle controls, history pagination, and role console views.
- **4. User Acceptance Testing (UAT):** Scenario-based evaluation performed by project team members acting as Data Subject, Administrator, and DPO personas against acceptance exit criteria.

5.2 Testing Types

- **Functional Testing:** Verification that all 20 functional requirements execute according to SRS specifications.
- **Regression Testing:** Automated test suites executed via GitHub Actions on every pull request to ensure zero degradation.
- **Performance & Scalability:** Load and stress testing using k6, simulating 50 concurrent virtual users and asserting response latencies (NFR-1 ≤ 2s, NFR-2 ≤ 3s).
- **Security Testing:** Automated vulnerability scanning (OWASP ZAP) plus manual penetration testing of auth, RBAC bypass, and SQL injection.
- **Usability & Accessibility:** Manual traversal and automated Lighthouse audits asserting WCAG 2.1 AA keyboard focus and contrast ratios.
- **Immutability & Integrity:** Executing direct SQL UPDATE and DELETE statements against consent_records to verify hard DB trigger rejection.

5.3 Entry & Exit Criteria

Quality Gates: Testing lifecycle stage transitions are governed by strict criteria:

- **Entry Criteria:** Git branch merged, build succeeds with 0 compile errors, unit tests pass 100%, test database seeded with baseline fixtures.
- **Exit Criteria:** 100% of planned test cases executed; 100% of High-priority test cases pass; zero open Critical or High severity defects; RTM shows 100% requirement coverage; test summary signed off.

5.4 Security Validation

Security testing covers the following threat vectors in depth:

- Assert password complexity enforcement (≥8 chars, letter + digit); verify bcrypt salt rounds = 12; verify raw passwords never appear in response payloads or logs.
- Test account lockout by submitting 5 consecutive invalid passwords; verify HTTP 423 Locked for 15 minutes; verify counter reset on valid login.
- Test RBAC authorization by attempting to call Admin endpoints (/api/v1/policies/{id}/publish) and DPO endpoints (/api/v1/users/{id}/consent-state?at=...) with a standard User JWT; verify HTTP 403 Forbidden.
- Submit SQL injection attack vectors (' OR 1=1 --) and XSS script tags (<script>alert(1)</script>) across all input fields; verify parameterization and sanitization.
- Direct DB attack: Attempt UPDATE consent_records SET action='GRANTED' WHERE id='...'; verify PostgreSQL error 'permission denied' or trigger exception.

6. Test Environment

Environment Element	Specifications & Tools Used
Hardware Platforms	Development workstations: 8-core CPU, 16GB RAM, SSD storage. Tested on Desktop, Laptop, and Tablet viewports.
Client Browsers	Google Chrome (v120+), Mozilla Firefox (v120+), Microsoft Edge (v120+), Safari (v17+). Mobile viewport emulation (360px).
Backend Runtime	Node.js 20 LTS running on Windows 11 and Ubuntu Linux 22.04 LTS containers.
Database Server	PostgreSQL 16 in Docker container with persistent volumes and NTP clock synchronization.
Test Automation Tools	Jest 29 (Unit), Supertest (API Integration), Cypress 13 (E2E), k6 (Performance load testing), OWASP ZAP (Security).
Test Data Fixtures	Seed script providing 3 test users (User, Admin, DPO), 5 standard processing purposes, 2 policy versions, and 100 mock consent rows.

7. Test Schedule

Milestone / Phase	Planned Dates	Testing Activities & Scope	Responsible Lead
Phase 1: Test Planning & Fixtures	06-Oct - 10-Oct-2026	Finalize STP, define test cases, configure Jest/Cypress harnesses, build database seed scripts.	Suman Diddimani (QA Lead)
Phase 2: Sprint 1 Verification	19-Oct - 23-Oct-2026	Execute Unit & Integration tests for Auth (TC-AUTH), Purpose Presentation (TC-CONS), and basic Opt-in/out.	Pradeep T, Vilas
Phase 3: Sprint 2 Verification	26-Oct - 30-Oct-2026	Execute tests for Policy Versioning (TC-POL), Audit Trail (TC-AUD), DPO Reconstruction (TC-SRCH), and Security (TC-SEC).	Suman Diddimani, Pradeep T
Phase 4: Load & Accessibility Audit	28-Oct - 29-Oct-2026	Run k6 load tests (50 concurrent users), execute Lighthouse accessibility audits, test backup recovery (TC-REL-03).	Pradeep T, Pranaav P.
Phase 5: Final UAT & Sign-Off	30-Oct-2026	End-to-end stakeholder UAT walkthrough, defect closure verification, final Test Summary Report compilation.	Team 6 / Course Faculty

8. Test Deliverables

The QA team will produce and maintain the following deliverables across the testing lifecycle:

- Software Test Plan (this document - STP v1.0).

- Detailed Test Case Specifications for all 41 test cases (TC-AUTH-01 to TC-RTM-01).
- Automated Test Suites (Jest unit test files, Supertest integration test files, Cypress E2E specs).
- Requirements Traceability Matrix (RTM) tracking requirement verification status (N, P, A).
- Test Execution Logs and CI Run Artifacts from GitHub Actions.
- Defect Tracking Logs documented via GitHub Issues with severity, steps to reproduce, and fix commits.
- Final Test Summary Report (TSR) providing quantitative pass rates, test metrics, and readiness recommendation.

9. Roles and Responsibilities

Project Role	Team Member	Specific Testing Responsibilities
QA Lead	SUMAN DIDDIMANI (PES1UG24AM409)	Authored Master Test Plan; designed security test suite (TC-SEC); verified RTM compliance; conducted final UAT sign-off.
Test & Automation Engineer	PRADEEP T (PES1UG24AM385)	Developed Jest and Supertest test automation scripts; orchestrated k6 performance test runs; managed CI pipeline test automation.
Development Lead	VILAS (PES1UG24AM415)	Developed backend domain services; resolved defect tickets; verified atomic transaction rollbacks; validated database schemas.
Frontend & Accessibility Lead	PRANAAV PRABHAKARAN (PES1UG24AM387)	Authored UI integration tests; conducted WCAG 2.1 AA keyboard/contrast audits; validated responsive layouts across viewports.
Course Coordinator / Faculty	Faculty In-Charge	Reviewed test deliverables, witnessed UAT demonstration, approved final milestone deliverables.

10. Risks and Mitigation

Testing Risk	Severity	Likelihood	Mitigation Strategy
Delay in stable backend build delivery for Sprint 1.	High	Medium	Establish strict API mocks using Prism/Postman so frontend and test case design proceed in parallel.
Append-only database accumulation causing test data pollution.	Medium	High	Maintain separate isolated test databases for Jest/Supertest; drop and re-seed schemas automatically between test runs.
Inaccurate timestamp testing due to local system clock variations.	High	Low	Enforce Docker-level NTP container synchronization and mock system clock timestamps in unit tests.
False positives in automated security vulnerability scans.	Medium	Medium	Review OWASP ZAP alerts manually; triage findings against system-specific context and adjust scanning rules.
Flaky browser E2E tests due to asynchronous UI transitions.	Medium	Medium	Use Cypress explicit route aliases (cy.wait('@grantConsent')) rather than arbitrary sleep delays.

11. Assumptions & Dependencies

- PostgreSQL 16 database server is available and accessible in local Docker test environments.
- NTP time synchronization is active, providing authoritative UTC timestamps.
- All Node.js dependencies are locked via package-lock.json to avoid version drift.
- Test seed data reflects realistic GDPR consent purposes and privacy policy texts.

12. Suspension & Resumption Criteria

Suspension Thresholds: Suspension Criteria: Testing of a module or full test cycle shall be suspended if:

- Database container fails to start or suffers continuous corruption preventing test data seeding.
- Authentication module is completely broken, blocking > 30% of dependent functional test suites.
- Critical defect (Severity 1) is uncovered that invalidates database immutability or causes catastrophic crash.

Resumption Thresholds: Resumption Criteria: Testing shall resume once:

- Development lead deploys a verified hotfix addressing the blocking defect.
- Test environment is reset, migrations re-run, and clean baseline test data re-seeded.
- Smoke test suite (TC-AUTH-01, TC-AUTH-02, TC-CONS-01) passes successfully.

13. Test Case Management & Traceability

This section contains the comprehensive specifications for all 41 test cases mapped to the SRS requirements, followed by the complete Requirements Traceability Matrix (RTM).

13.1 Detailed Test Case Specifications

■ Test Case: TC-AUTH-01 (Authentication - Mapped to FR-1)
• Title: User Registration with Unique Email
• Pre-Conditions: Database running; user not previously registered.
• Execution Steps: 1. Navigate to /register. 2. Enter full name, unique email, password (≥8 chars). 3. Submit form.
• Test Input / Data: Name: 'Bob User', Email: 'bob@example.com', Password: 'Password123!'
• Expected Results: User record created with 'User' role; password hashed with bcrypt salt 12; HTTP 201 returned.
• Actual Result / Verification Status: PASS - HTTP 201; role USER; bcrypt hash cost 12 ($2a$12$); e-mail stored AES-256-GCM encrypted with an HMAC lookup hash. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-AUTH-02 (Authentication - Mapped to FR-2)
• Title: User Login with Valid Credentials
• Pre-Conditions: User account exists in database.
• Execution Steps: 1. Navigate to /login. 2. Enter registered email and password. 3. Click 'Sign In'.
• Test Input / Data: Email: 'bob@example.com', Password: 'Password123!'
• Expected Results: JWT issued in an httpOnly session cookie; user redirected to the home screen of their role (User: /dashboard, Admin: /admin, DPO: /dpo); LOGIN_SUCCEEDED written to the audit trail with a UTC timestamp.
• Actual Result / Verification Status: PASS - HTTP 200; JWT in httpOnly gdpr_session cookie; LOGIN_SUCCEEDED audit entry with UTC time; landing page USER /dashboard, ADMIN /admin, DPO /dpo. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-AUTH-03 (Authentication - Mapped to FR-3)
• Title: Logout Ends the Session Immediately
• Pre-Conditions: User is logged in with a valid session.
• Execution Steps: 1. Click 'Logout'. 2. Press browser Back / open /dashboard. 3. Call GET /api/v1/me/consents with the old session cookie.
• Test Input / Data: Session cookie captured before logout.
• Expected Results: User is returned to /login; protected pages are not shown; the API returns HTTP 401 UNAUTHENTICATED for the old session.
• Actual Result / Verification Status: PASS - after logout the browser is on /login, /dashboard redirects to /login, and the old cookie gets HTTP 401 UNAUTHENTICATED. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-CONS-01 (Consent Presentation - Mapped to FR-4)
• Title: Display Active Processing Purposes
• Pre-Conditions: At least 3 active purposes exist in database.
• Execution Steps: 1. Log in as User. 2. Observe displayed purpose cards.
• Test Input / Data: Purposes: Marketing e-mails, Personalised recommendations, Usage analytics, Sharing with partners.
• Expected Results: All active purposes rendered with name, plain-language description and current status (Not given / Granted / Withdrawn).

• Actual Result / Verification Status: PASS - all active purposes shown as cards with name, plain-language description and status badge (Not given / Granted / Withdrawn). (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-CONS-02 (Policy Presentation - Mapped to FR-5)
• Title: Display Currently Published Policy
• Pre-Conditions: Policy version v1.0 is published.
• Execution Steps: 1. Log in as User. 2. Click 'View Privacy Policy'.
• Test Input / Data: Active policy: v1.0.
• Expected Results: Policy title, version tag ('v1.0'), effective date, and full policy text displayed cleanly.
• Actual Result / Verification Status: PASS - title, version 1.0, effective date and the full text are shown. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-PURP-01 (Purpose Management - Mapped to FR-6)
• Title: Administrator Manages Purposes
• Pre-Conditions: Logged in as Administrator.
• Execution Steps: 1. POST /api/v1/purposes as Admin. 2. PATCH /api/v1/purposes/{Analytics}/deactivate. 3. Open the User dashboard.
• Test Input / Data: Code: 'PURP_NEWSLETTER', Name: 'Newsletter', Description text.
• Expected Results: Purpose created; deactivated purpose immediately hidden from User dashboard; audit log recorded.
• Actual Result / Verification Status: PASS (via API) - PURP_NEWSLETTER created (201), ANALYTICS deactivated (200) and hidden from the user dashboard at once; PURPOSE_CREATED / PURPOSE_DEACTIVATED audited. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-CONS-03 (Consent Management - Mapped to FR-7)
• Title: Explicit User Opt-In (Grant Consent)
• Pre-Conditions: User logged in; Marketing purpose status is 'Not Given'.
• Execution Steps: 1. Navigate to the Consent Dashboard. 2. Click 'Grant' for Marketing e-mails.
• Test Input / Data: Purpose: MARKETING_EMAIL, Action: 'GRANTED'.
• Expected Results: New record inserted in consent_records; status updates to 'Granted' in ≤2s; audit event written.
• Actual Result / Verification Status: PASS - 201 in about 40 ms; new consent_records row; status Granted; CONSENT_GRANTED audited. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-CONS-04 (Consent Management - Mapped to FR-8)
• Title: Explicit User Opt-Out (Withdraw Consent)
• Pre-Conditions: User has active 'Granted' consent for Marketing.
• Execution Steps: 1. Click 'Withdraw' on a granted purpose (one click, as easy as granting).
• Test Input / Data: Purpose: MARKETING_EMAIL, Action: 'WITHDRAWN'.
• Expected Results: New record inserted with action 'WITHDRAWN'; status updates to 'Withdrawn'; withdrawal audit written.
• Actual Result / Verification Status: PASS - new WITHDRAWN row; status Withdrawn; CONSENT_WITHDRAWN audited. Withdrawal is one click (no confirm dialog), by design. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-CONS-05 (Consent Management - Mapped to FR-9)
• Title: Capture UTC Timestamp & Policy Version
• Pre-Conditions: User executes opt-in action.
• Execution Steps: 1. Execute consent grant. 2. Query database for inserted record.
• Test Input / Data: System clock synchronized via NTP.
• Expected Results: Field recorded_at populated with a UTC timestamp (timestamptz, ISO-8601 'Z' in the API); policy_version_id matches the current published policy.
• Actual Result / Verification Status: PASS - recorded_at is timestamptz in UTC (API returns ISO-8601 'Z'); policy_version_id equals the published policy. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-CONS-06 (Consent Management - Mapped to FR-10)
• Title: Reject Invalid Consent Actions
• Pre-Conditions: Purpose 'Analytics' is inactive; user already has 'Granted' for 'Marketing'.
• Execution Steps: 1. POST /api/v1/me/consents GRANT for 'Analytics'. 2. POST GRANT again for 'Marketing'. 3. With no published policy, POST GRANT for any purpose.

• Test Input / Data: Inactive purpose; duplicate grant; no published policy.
• Expected Results: Responses 409 PURPOSE_INACTIVE, 409 CONSENT_UNCHANGED and 409 NO_PUBLISHED_POLICY with a message; no consent record is created.
• Actual Result / Verification Status: PASS - 409 PURPOSE_INACTIVE, 409 CONSENT_UNCHANGED, 409 NO_PUBLISHED_POLICY, 400 for an unknown action; no record written in any case. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-HIST-01 (Consent History - Mapped to FR-11)
• Title: Verify Append-Only Storage Model
• Pre-Conditions: User toggles consent 4 times.
• Execution Steps: 1. Toggle grant/withdraw 4 times. 2. Execute SQL COUNT(*) on consent_records for user.
• Test Input / Data: 4 sequential toggle actions.
• Expected Results: Exactly 4 rows exist in table; no existing rows were updated or deleted.
• Actual Result / Verification Status: PASS - 4 toggles give exactly 4 rows; an UPDATE on them is rejected by the append-only trigger. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-HIST-02 (Consent History - Mapped to FR-12)
• Title: Reverse-Chronological History View
• Pre-Conditions: User has 5 recorded consent actions over time.
• Execution Steps: 1. Navigate to 'Consent History'. 2. Verify display ordering.
• Test Input / Data: Timestamps T1 < T2 < T3 < T4 < T5.
• Expected Results: Actions displayed strictly in reverse chronological order: T5 first, T1 last, with purpose, action, policy ver.
• Actual Result / Verification Status: PASS - 5 entries, strictly newest first, each with purpose, action and policy version. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-POL-01 (Policy Management - Mapped to FR-13)
• Title: Create Draft Policy Version
• Pre-Conditions: Logged in as Administrator.
• Execution Steps: 1. Navigate to Policy Management. 2. Enter version tag 'v1.1' and text. 3. Save as Draft.
• Test Input / Data: Version: '1.1', Status: 'DRAFT'.
• Expected Results: Record created in policy_versions with status DRAFT; not visible to general users (GET as USER returns 404).
• Actual Result / Verification Status: PASS after fix - draft 1.1 saved as DRAFT. Defect D-01 found on first run (a USER could open a draft by id); fixed and re-tested: USER now gets 404. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-POL-02 (Policy Management - Mapped to FR-14)
• Title: Publish Policy & Supersede Previous
• Pre-Conditions: v1.0 is Published; v1.1 is Draft.
• Execution Steps: 1. Administrator clicks 'Publish v1.1'. 2. Confirm publication.
• Test Input / Data: Target policy: v1.1.
• Expected Results: v1.1 status becomes PUBLISHED and effective_at is set to the publish time; v1.0 becomes SUPERSEDED.
• Actual Result / Verification Status: PASS - 1.1 PUBLISHED with effective_at = publish time; 1.0 SUPERSEDED; only one published version. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-POL-03 (Policy Management - Mapped to FR-15)
• Title: Immutability of Published/Superseded Policies
• Pre-Conditions: v1.0 is Superseded; v1.1 is Published.
• Execution Steps: 1. Administrator attempts to edit content of v1.0 or v1.1.
• Test Input / Data: PATCH /api/v1/policies/{id of v1.0} with modified text.
• Expected Results: HTTP 409 POLICY_LOCKED returned; published and superseded versions cannot be edited (also blocked by a database trigger).
• Actual Result / Verification Status: PASS - PATCH on 1.0 and 1.1 returns 409 POLICY_LOCKED; a direct SQL UPDATE is rejected by a trigger. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-POL-04 (Policy Management - Mapped to FR-16)
• Title: User Notification on Policy Update
• Pre-Conditions: User consented under v1.0; v2.0 published.

• Execution Steps: 1. User logs in after v2.0 published. 2. Inspect Dashboard alerts.
• Test Input / Data: User has active consents linked to older policy version v1.0.
• Expected Results: Dashboard banner appears: 'Our privacy policy changed to version 2.0' with the change summary, a link to the new policy and a choice to keep or review consents.
• Actual Result / Verification Status: PASS - after 2.0 is published the user sees 'Our privacy policy changed to version 2.0' with the change summary and a link to the new policy. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-AUD-01 (Audit Trail - Mapped to FR-17)
• Title: Comprehensive Audit Event Logging
• Pre-Conditions: Actions performed: Login, Grant, Withdraw, Policy Publish.
• Execution Steps: 1. Perform actions. 2. Query the audit_entries table.
• Test Input / Data: Distinct event types triggered.
• Expected Results: Audit records exist for all actions, capturing actor_id, action, target, outcome, details JSON, UTC timestamp and SHA-256 hash (hash chain).
• Actual Result / Verification Status: PASS - 16 event types recorded in audit_entries with actor_id, action, target, outcome, details JSON, UTC created_at and SHA-256 hash. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-AUD-02 (Audit Trail - Mapped to FR-18)
• Title: DPO Real-Time Audit Inspection
• Pre-Conditions: Logged in as DPO_Auditor.
• Execution Steps: 1. Navigate to Audit Console. 2. Inspect live audit feed.
• Test Input / Data: DPO role credentials.
• Expected Results: Full audit log visible with actor, action, timestamp, target entity; read-only controls.
• Actual Result / Verification Status: PASS - DPO console shows consent records, audit trail and time travel; no create/edit/delete routes (POST/DELETE /audit -> 404). (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SRCH-01 (Search & Retrieval - Mapped to FR-19)
• Title: DPO Multi-Parameter Filter & Search
• Pre-Conditions: Audit trail contains 50+ mixed records.
• Execution Steps: 1. DPO filters by user email, purpose 'Marketing', date range. 2. Click 'Search'.
• Test Input / Data: Search criteria: Email + Purpose + Range.
• Expected Results: Filtered results returned in ≤3s (NFR-2); non-matching records excluded.
• Actual Result / Verification Status: PASS - e-mail + purpose + date range returns only matching rows in about 40 ms (target 3 s). (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SRCH-02 (Search & Retrieval - Mapped to FR-20)
• Title: Historical Consent State Reconstruction
• Pre-Conditions: User consented at T1 (01-Oct), withdrew at T3 (10-Oct). Target date T2 (05-Oct).
• Execution Steps: 1. DPO enters user ID and target date T2. 2. Click 'Reconstruct State'.
• Test Input / Data: User e-mail or ID, target moment T2 (between the first grant and the first withdrawal).
• Expected Results: Engine computes state as 'Granted' under governing policy.
• Actual Result / Verification Status: PASS - state at T2 reconstructed as GRANTED under policy 1.0. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SEC-01 (Security - Mapped to SEC-1)
• Title: Password Policy & Bcrypt Hashing
• Pre-Conditions: Registration endpoint.
• Execution Steps: 1. Attempt passwords: 'short', 'nouppercase1', 'ValidPass123!'. 2. Check the DB hash.
• Test Input / Data: Invalid vs valid passwords.
• Expected Results: Passwords under 8 characters rejected (SEC-1); 'nouppercase1' and 'ValidPass123!' accepted; hashed with bcrypt (cost 12); no plaintext in DB.
• Actual Result / Verification Status: PASS - 'short' rejected (400); 'nouppercase1' and 'ValidPass123!' accepted (SEC-1 = at least 8 characters); bcrypt cost 12; no plaintext. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SEC-02 (Security - Mapped to SEC-2)

• Title: Server-Side RBAC Enforcement
• Pre-Conditions: Standard User JWT token.
• Execution Steps: 1. Send POST /api/v1/policies/{id}/publish. 2. Send GET /api/v1/audit.
• Test Input / Data: User token calling Admin & DPO routes.
• Expected Results: Both requests rejected with HTTP 403 Forbidden; attempted privilege escalation logged.
• Actual Result / Verification Status: PASS - USER gets 403 on publish and on /audit; both ACCESS_DENIED attempts are audited. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SEC-03 (Security - Mapped to SEC-3)
• Title: Account Lockout & Session Expiration
• Pre-Conditions: Registered user account.
• Execution Steps: 1. Submit 5 invalid passwords. 2. Submit valid password on 6th attempt. 3. Test expired JWT.
• Test Input / Data: 5 consecutive bad passwords.
• Expected Results: Account locked for 15 minutes (HTTP 423); login rejected even with correct password until timer expires.
• Actual Result / Verification Status: PASS - 5 wrong passwords lock the account for 15 min; 6th attempt with the right password gets 423; expired JWT gets 401. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SEC-04 (Security - Mapped to SEC-4)
• Title: Admin-Only Role Management
• Pre-Conditions: User and Admin tokens.
• Execution Steps: 1. User attempts to change role to Admin. 2. Admin promotes user. 3. Check audit log.
• Test Input / Data: Role modification payload.
• Expected Results: User attempt rejected (HTTP 403); Admin change succeeds and writes role change audit event.
• Actual Result / Verification Status: PASS - USER role change 403; ADMIN change 200 with USER_ROLE_CHANGED audit (old and new role). (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SEC-05 (Security - Mapped to SEC-5)
• Title: Mandatory TLS 1.2+ Encryption
• Pre-Conditions: HTTP vs HTTPS endpoints.
• Execution Steps: 1. Send plain HTTP request. 2. Inspect TLS handshake cipher suite.
• Test Input / Data: Production build behind HTTPS (https://gdpr-consent-manager.onrender.com) and plain-HTTP request to the production server.
• Expected Results: Plain HTTP redirected to HTTPS (308) with HSTS; TLS 1.2 or 1.3 negotiated with a valid certificate.
• Actual Result / Verification Status: PASS - production mode answers plain HTTP with 308 to HTTPS and sends HSTS; the deployed site uses TLS 1.3 (X25519MLKEM768, AES_128_GCM) with a valid certificate. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SEC-06 (Security - Mapped to SEC-6)
• Title: Ledger Immutability Enforcement
• Pre-Conditions: Direct SQL client connected as application role.
• Execution Steps: 1. Execute: UPDATE consent_records SET action='GRANTED' WHERE id='...'. 2. Execute DELETE.
• Test Input / Data: SQL UPDATE and DELETE commands.
• Expected Results: Both statements fail with a trigger exception; if the trigger is bypassed by a superuser, Verify integrity reports HASH_MISMATCH.
• Actual Result / Verification Status: PASS - UPDATE/DELETE on consent_records and audit_entries rejected by triggers; a superuser bypass is detected by Verify integrity (HASH_MISMATCH). (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SEC-07 (Security - Mapped to SEC-7)
• Title: Input Validation & OWASP Attack Defense
• Pre-Conditions: Form inputs and API payloads.
• Execution Steps: 1. Submit SQLi: ' OR '1'='1. 2. Submit XSS: <script>alert('xss')</script> in purpose name.
• Test Input / Data: Malicious attack payloads.
• Expected Results: SQLi safely escaped via parameterized queries; XSS sanitized / HTML-encoded; no script execution.
• Actual Result / Verification Status: PASS - SQLi payloads treated as data (400 / 0 rows); <script> name stored and shown as literal text, no script ran; cross-site POST blocked (403). (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SEC-08 (Security - Mapped to NFR-10)
• Title: Encryption at Rest for Data & Backups
• Pre-Conditions: PostgreSQL database files and backup archives.
• Execution Steps: 1. Inspect users.email in the database. 2. Inspect a pg_dump and the application backup file. 3. Confirm provider storage encryption.
• Test Input / Data: Disk blocks and backup dump files.
• Expected Results: E-mails encrypted with AES-256-GCM (field level); no plaintext e-mail in dumps or backups; passwords only as bcrypt hashes; storage encrypted at rest by the database provider.
• Actual Result / Verification Status: PASS (changed method) - all e-mails AES-256-GCM encrypted; pg_dump and app backup contain no plaintext e-mail; passwords only as bcrypt; Neon encrypts storage at rest. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-PERF-01 (Performance - Mapped to NFR-1)
• Title: Consent Action Latency ≤ 2 Seconds
• Pre-Conditions: Server running under standard load.
• Execution Steps: 1. Send POST /api/v1/me/consents (GRANT) via k6. 2. Measure round-trip time.
• Test Input / Data: k6 script perf/consent-actions.js: 50 virtual users, each with its own account, 1 minute.
• Expected Results: At least 95% of consent actions complete within 2 s with 50 concurrent users; status badge updated.
• Actual Result / Verification Status: PASS - 50 concurrent users, 1 min, 1,253 consent actions: p95 491 ms, 0 % errors. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-PERF-02 (Performance - Mapped to NFR-2)
• Title: DPO Search / Filter Latency ≤ 3 Seconds
• Pre-Conditions: Database populated with 100,000 consent records.
• Execution Steps: 1. Run k6 perf/dpo-search.js (consent and audit filters, paging). 2. Measure latency.
• Test Input / Data: 10 DPO sessions for 1 minute; first page of up to 50 rows.
• Expected Results: At least 95% of queries return the first page (50 rows) within 3 s.
• Actual Result / Verification Status: PASS - 10 DPO sessions, 1 min, 550 searches: p95 42 ms, 0 % errors. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-SCAL-01 (Scalability - Mapped to NFR-3)
• Title: 50 Concurrent Users & 500k Records
• Pre-Conditions: Database seeded with 500,000 historical consent records.
• Execution Steps: 1. Execute k6 load test simulating 50 concurrent virtual users for 10 minutes.
• Test Input / Data: Volume database with 10,000+ users and 500,000+ consent records; 50 VUs toggling consents plus 10 DPO search sessions for 10 minutes.
• Expected Results: No HTTP 5xx errors; NFR-1 and NFR-2 targets still met with 50 concurrent users, 10,000 users and 500,000 consent records.
• Actual Result / Verification Status: PASS - 10,059 users / 517,306+ records, 50 users + 10 DPO sessions for 10 min: consent p95 1171 ms, search p95 786 ms, 0 HTTP 5xx, 0 % failed. Defect D-03 found on the first run and fixed. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-REL-01 (Availability - Mapped to NFR-4)
• Title: 99% System Operational Uptime
• Pre-Conditions: Automated uptime monitor pinging /api/health every 30s.
• Execution Steps: 1. Monitor system continuously over test cycle. 2. Calculate uptime percentage.
• Test Input / Data: UptimeRobot check of /api/v1/health every 5 minutes on the deployed system, plus a 1-second local health probe during the load tests.
• Expected Results: Availability is at least 99% of scheduled demo/evaluation hours in the month.
• Actual Result / Verification Status: PASS - UptimeRobot monitor on the deployed /api/v1/health every 5 min: Up, 100 % (0 incidents) since deployment on 03-11-2026; local 1-s probe during the load tests: 1,446 of 1,459 checks OK (99.1 %), the misses were only during the 60-user login bursts. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-REL-02 (Reliability - Mapped to NFR-5)
• Title: Transactional Atomicity of Consent & Audit

• Pre-Conditions: Simulate database constraint error on audit_log table.
• Execution Steps: 1. Trigger consent action while audit table is mocked to fail. 2. Inspect consent_records.
• Test Input / Data: Forced failure in audit insert step.
• Expected Results: Transaction rolls back completely; zero orphaned consent records inserted; HTTP 500 returned.
• Actual Result / Verification Status: PASS - forced audit failure gives HTTP 500 and zero orphan consent rows; works again once the fault is removed. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-REL-03 (Recovery - Mapped to NFR-11)
• Title: Daily Backup & Restore within RTO (4 Hours)
• Pre-Conditions: Production database with active data.
• Execution Steps: 1. Run the backup script (JSON export of all tables). 2. Create an empty database. 3. Run the restore script. 4. Run Verify integrity.
• Test Input / Data: Complete application backup file.
• Expected Results: Database restored cleanly; 100% record integrity verified; restore completes within 4 hours (RTO).
• Actual Result / Verification Status: PASS - backup of 5,377 rows in 0.9 s, restored into an empty database in 2.4 s (RTO 4 h); row counts identical; Verify integrity on the restored copy: both hash chains intact. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-UX-01 (Usability - Mapped to NFR-6)
• Title: Consent Grant in ≤ 1 Min and ≤ 3 Clicks
• Pre-Conditions: First-time user after login.
• Execution Steps: 1. Log in (lands on the Dashboard). 2. Click 'Grant' on a purpose.
• Test Input / Data: Standard User journey.
• Expected Results: Consent granted in at most 3 clicks and under 1 minute; participants confirm they understood what they agreed to.
• Actual Result / Verification Status: PASS - 1 click (Grant) from the dashboard, status Granted in under 1 s; login lands on the dashboard. Participant timings: see Accessibility & Usability Report. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-UX-02 (Accessibility - Mapped to NFR-7)
• Title: WCAG 2.1 AA Keyboard & Contrast Audit
• Pre-Conditions: All application screens.
• Execution Steps: 1. Navigate the app using Tab, Shift+Tab and Enter only. 2. Run an automated axe-core WCAG 2.1 AA audit on every page.
• Test Input / Data: No mouse usage; contrast checker tool.
• Expected Results: All controls reachable by keyboard with a visible focus indicator; contrast ratio at least 4.5:1; zero axe-core WCAG 2.1 A/AA violations.
• Actual Result / Verification Status: PASS - axe-core WCAG 2.1 A/AA scan of 8 pages: 0 violations (incl. colour contrast); keyboard-only login and grant work with a visible focus ring. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-DATA-01 (Data Retention - Mapped to NFR-8)
• Title: Retention Policy Compliance
• Pre-Conditions: Historical consent records with varying ages.
• Execution Steps: 1. Verify retention query logic against the configured retention period (default 3 years).
• Test Input / Data: Records from past dates.
• Expected Results: Records within retention window preserved immutably; no premature truncation.
• Actual Result / Verification Status: PASS - no delete or purge path exists; DELETE blocked by triggers; oldest records still present; retention helper tested. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-DATA-02 (Data Accuracy - Mapped to NFR-13)
• Title: NTP UTC Synchronization Verification
• Pre-Conditions: Server chrony daemon active.
• Execution Steps: 1. Inspect the types of all timestamp columns. 2. Compare API time with the client clock. 3. Confirm hosting NTP.
• Test Input / Data: System clock offset check.
• Expected Results: All stored timestamps are UTC (timestamptz); API times in ISO-8601 'Z'; host clocks synchronised by the hosting providers.
• Actual Result / Verification Status: PASS - every timestamp column is timestamptz (0 naive); all API times are UTC 'Z'. Host

clocks are NTP-synchronised by Render/Neon. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-PRIV-01 (Privacy - Mapped to NFR-9)
• Title: Data Minimization Audit
• Pre-Conditions: Database schema and table dumps.
• Execution Steps: 1. Inspect all columns of all tables. 2. Verify absence of unnecessary personal data.
• Test Input / Data: Database DDL.
• Expected Results: Only name, email, password hash, role, consent actions, and audit data stored; no sensitive/special category data.
• Actual Result / Verification Status: PASS - only name, encrypted e-mail, password hash, role/account state, consents, policies and audit data are stored. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-MAINT-01 (Maintainability - Mapped to NFR-12)
• Title: Layered Architecture & ≥70% Test Coverage
• Pre-Conditions: Code repository and test runner.
• Execution Steps: 1. Run 'npm run test:coverage -w server' and 'npm run test:coverage -w client'. 2. Inspect layering in source files.
• Test Input / Data: Jest coverage report.
• Expected Results: CI report shows passing tests and at least 70% service-layer coverage; clear separation of UI, API, Service, DAO.
• Actual Result / Verification Status: PASS - 225 automated tests pass in CI; service-layer statement coverage 94.8 % (target 70 %); layers: React UI -> API routes -> services -> Prisma (DAO) -> PostgreSQL. (executed 03-11-2026; evidence: System Validation Report)

■ Test Case: TC-RTM-01 (Traceability - Mapped to NFR-14)
• Title: Requirements Traceability Verification
• Pre-Conditions: SRS, SAD, and STP documents.
• Execution Steps: 1. Cross-reference every requirement ID in SRS against STP test cases and RTM table.
• Test Input / Data: Complete requirement list.
• Expected Results: 100% bidirectional traceability confirmed; zero orphaned requirements or untraceable test cases.
• Actual Result / Verification Status: PASS - 41 requirements (20 FR, 7 SEC, 14 NFR) each map to exactly one test case, and all 41 test cases map back to a requirement: 100 % bidirectional, no orphans. (executed 03-11-2026; evidence: System Validation Report)

13.2 Requirements Traceability Matrix (RTM)

The Requirements Traceability Matrix (RTM) below maps every requirement from the SRS to its corresponding design area, verification test case, and acceptance status (Status values: N = Not yet verified, P = Passed, A = Accepted):

Req ID	SRS Ref	Module / Design Area	Test Case Reference(s)	Status
FR-1	4.1	Authentication	TC-AUTH-01	**P**
FR-2	4.1	Authentication	TC-AUTH-02	**P**
FR-3	4.1	Authentication	TC-AUTH-03	**P**
FR-4	4.2	Consent Purpose & Policy Presentation	TC-CONS-01	**P**
FR-5	4.2	Consent Purpose & Policy Presentation	TC-CONS-02	**P**
FR-6	4.2	Purpose Management Service	TC-PURP-01	**P**
FR-7	4.3	Consent Management Service (Opt-In)	TC-CONS-03	**P**
FR-8	4.3	Consent Management Service (Opt-Out)	TC-CONS-04	**P**
FR-9	4.3	Consent Management Service (UTC/Policy)	TC-CONS-05	**P**
FR-10	4.3	Consent Management Service (Validation)	TC-CONS-06	**P**
FR-11	4.4	Consent History Service (Append-Only)	TC-HIST-01	**P**
FR-12	4.4	Consent History Service (Reverse Chron)	TC-HIST-02	**P**

FR-13	4.5	Policy Version Service (Draft)	TC-POL-01	P
FR-14	4.5	Policy Version Service (Publish/Supersede)	TC-POL-02	P
FR-15	4.5	Policy Version Service (Immutability)	TC-POL-03	P
FR-16	4.5	Policy Version Service (User Alerts)	TC-POL-04	P
FR-17	4.6	Audit & Compliance Review (Logging)	TC-AUD-01	P
FR-18	4.6	Audit & Compliance Review (DPO Feed)	TC-AUD-02	P
FR-19	4.7	Search & Historical State (Search/Filter)	TC-SRCH-01	P
FR-20	4.7	Search & Historical State (Reconstruction)	TC-SRCH-02	P
SEC-1	5.1.2	Security (Password & Bcrypt)	TC-SEC-01	P
SEC-2	5.1.2	Security (Server-Side RBAC)	TC-SEC-02	P
SEC-3	5.1.2	Security (Lockout & Session)	TC-SEC-03	P
SEC-4	5.1.2	Security (Admin Role Governance)	TC-SEC-04	P
SEC-5	5.1.2	Security (TLS 1.2+ Encryption)	TC-SEC-05	P
SEC-6	5.1.2	Security (Ledger Immutability)	TC-SEC-06	P
SEC-7	5.1.2	Security (Input Sanitization/OWASP)	TC-SEC-07	P
NFR-1	5.2	Performance (Consent Latency ≤ 2s)	TC-PERF-01	P
NFR-2	5.2	Performance (Search Latency ≤ 3s)	TC-PERF-02	P
NFR-3	5.2	Scalability (50 VUs, 500k Records)	TC-SCAL-01	P
NFR-4	5.2	Availability (99% Uptime)	TC-REL-01	P
NFR-5	5.2	Reliability (Consent + Audit Atomicity)	TC-REL-02	P
NFR-6	5.2	Usability (≤ 1 min, ≤ 3 clicks)	TC-UX-01	P
NFR-7	5.2	Accessibility (WCAG 2.1 AA)	TC-UX-02	P
NFR-8	5.2	Data Retention (3-Year Default)	TC-DATA-01	P
NFR-9	5.2	Privacy (Data Minimization)	TC-PRIV-01	P
NFR-10	5.2	Security (Encryption at Rest)	TC-SEC-08	P
NFR-11	5.2	Recovery (RTO ≤ 4h, RPO ≤ 24h)	TC-REL-03	P
NFR-12	5.2	Maintainability (Layered, ≥70% Test Cov)	TC-MAINT-01	P
NFR-13	5.2	Data Accuracy (NTP UTC Timestamps)	TC-DATA-02	P
NFR-14	5.2	Traceability (Full RTM Verification)	TC-RTM-01	P

14. Test Metrics & Reporting

Test execution progress, defect quality, and test effectiveness will be quantified using standard software engineering metrics:

- **1. Test Execution Rate:** Percentage of planned test cases executed against total test cases (Target: 100%).
- **2. Test Pass Rate:** Ratio of passed test cases to total executed test cases: (Passed / Executed) * 100% (Target: ≥ 98% in final regression).
- **3. Defect Density:** Number of confirmed defects per 1,000 lines of source code (Target: < 2 defects/KLOC).
- **4. Requirement Coverage:** Percentage of SRS requirements linked to at least one passing test case: (Covered Reqs / Total Reqs) * 100% (Target: 100%).
- **5. Defect Ageing:** Average elapsed time from defect creation to verified resolution in CI (Target: Critical < 24h, High < 48h).

Reporting Protocol: Reporting Protocol:

- Daily automated CI execution reports generated by GitHub Actions upon pull request merge.
- Bi-weekly sprint test summary presented to project team and faculty during Sprint 1 and Sprint 2 reviews.
- Final Comprehensive Test Summary Report (TSR) containing defect logs, execution charts, and release sign-off.

14.1 Test Execution Results (Sprint 3, 02-06 Nov 2026)

All test cases were executed on the running system on 03-11-2026. Full evidence is in docs/07-Test-Reports/System_Validation_Report.pdf; automated test results in the Unit Test, Code Coverage and Branch Coverage reports.

- **Test Execution Rate:** 41 / 41 = 100 % (target 100 %).
- **Test Pass Rate:** 41 / 41 = 100 % in the final run (target ≥ 98 %). One case (TC-POL-01) failed on the first run and passed after the fix.
- **Defect Density:** 3 defects / 4.7 KLOC = 0.64 per KLOC (target < 2).
- **Requirement Coverage:** 41 / 41 requirements (20 FR, 7 SEC, 14 NFR) linked to a passing test case = 100 %.
- **Defect Ageing:** both defects fixed and re-tested on the day they were found (< 24 h).
- **Automated tests:** 225 unit/integration tests, all passing; server statement coverage 95.7 %, branch 88.5 %; client statement 89.2 %, branch 85.3 %.

Defects found during system testing:

- **D-01** (TC-POL-01, High): A logged-in USER could read an unpublished DRAFT policy with GET /api/v1/policies/{id}. Fix: GET /policies/:id now returns 404 POLICY_NOT_FOUND for a DRAFT when the caller is a USER; ADMIN and DPO still see drafts. New unit test added. Status: Fixed, re-tested PASS.
- **D-02** (TC-PERF-01/02, Medium): k6 load scripts lost the session cookie after the first iteration (k6 resets cookies by default), so later requests got 401; setup counted 409 'already registered' as failures. Fix: Added noCookiesReset: true to both scripts and marked 409 as an expected status in setup. Status: Fixed, re-tested PASS.
- **D-03** (TC-SCAL-01, High): When 50 users logged in at the same second, some audit-trail writes waited longer than Prisma's default 5 s transaction limit: 25 LOGIN_SUCCEEDED entries were lost and 1 consent action returned 500 (rolled back). Fix: Interactive transactions now get maxWait 15 s / timeout 30 s (server/src/lib/prisma.ts), so chained audit writes queue instead of failing. Status: Fixed, re-tested PASS (0 lost, 0 errors).

Test cases revised after Sprint 1-2 (implemented design differs from the original plan):

- **Error codes** (TC-CONS-06, TC-POL-03): planned '422/NO_CHANGE/POLICY_NOT_DRAFT', implemented '409 PURPOSE_INACTIVE / CONSENT_UNCHANGED / NO_PUBLISHED_POLICY / POLICY_LOCKED'. All are business-rule conflicts, so one status (409) with clear codes is used, as in the SAD API table.
- **Purpose category** (TC-CONS-01): planned 'Card shows a category', implemented 'No category field'. Purposes are identified by a stable code (e.g. MARKETING_EMAIL); a category added no value for users.
- **Purpose management UI** (TC-PURP-01): planned 'Admin screen for purposes', implemented 'Admin API only (POST/PATCH /purposes)'. Sprint capacity went to policies, users and the DPO console; the API is complete, audited and tested.
- **Withdraw confirmation** (TC-CONS-04, TC-UX-01): planned 'Confirm dialog / 3 clicks', implemented 'One click for both grant and withdraw'. GDPR Art. 7(3): withdrawing must be as easy as giving consent.
- **Password rule** (TC-SEC-01): planned ''nouppercase1' rejected', implemented 'Only length >= 8 (max 72)'. SRS SEC-1 only requires 8 characters (NIST SP 800-63B guidance).

- **Encryption at rest** (TC-SEC-08): planned 'Inspect raw disk blocks', implemented 'Field-level AES-256-GCM e-mail encryption + provider storage encryption'. Managed database has no raw disk access; field-level encryption is stronger for personal data.
- **Accessibility tool** (TC-UX-02): planned 'Lighthouse score >= 95', implemented 'axe-core WCAG 2.1 A/AA scan (0 violations)'. axe-core is the engine Lighthouse uses for accessibility; it ran inside the test browser.
- **NTP check** (TC-DATA-02): planned 'Offset vs pool.ntp.org < 20 ms', implemented 'UTC storage verified; NTP handled by Render/Neon'. The app runs on managed hosting; no NTP container is ours to run.
- **Load test volume** (TC-SCAL-01): planned 'Real 10,000 users / 500,000 records', implemented 'Synthetic volume rows inserted by SQL (hash fields synthetic)'. Creating 500k chained records through the API would take hours; the test measures query speed at volume.
- **Backup format** (TC-REL-03): planned 'pg_dump / drop / restore', implemented 'App backup script (JSON of all tables) restored into a new DB + integrity check'. Works on Neon free tier without superuser tools; pg_dump also verified in TC-SEC-08.
- **Uptime window** (TC-REL-01): planned '2,880 checks over a month', implemented 'UptimeRobot every 5 min since deployment (3 Nov) + local probe'. System deployed in Sprint 3; the monitor keeps running until the final demo.
- **Table/column names** (TC-AUD-01, TC-CONS-05): planned 'audit_log, recorded_at_utc', implemented 'audit_entries, recorded_at (timestamptz)'. Names follow the final Prisma schema.

15. Approvals

The undersigned project stakeholders and academic evaluators confirm that this Software Test Plan (STP) establishes a complete, rigorous, and acceptable verification framework for the Simplified GDPR Consent Manager v1.0:

Project Role	Name	Designation / Department	Signature / Date
QA Lead	SUMAN DIDDIMANI	PES1UG24AM409 / Dept. of CSE	Suman Diddimani / 10-10-2026
Development Lead	VILAS	PES1UG24AM415 / Dept. of CSE	Vilas / 10-10-2026
Test & Automation Eng.	PRADEEP T	PES1UG24AM385 / Dept. of CSE	Pradeep T / 10-10-2026
Frontend Lead	PRANAAV PRABHAKARAN	PES1UG24AM387 / Dept. of CSE	Pranaav P. / 10-10-2026
Course Coordinator	Faculty In-Charge	Department of Computer Science & Engineering	Pending Final Sign-Off